

Authority for Personal Data
P.O. Box 93374, 2509 AJ The Hague
Hoge Nieuwstraat 8, 2514 EL The Hague
T 070 8888 500 - F 088 0712140
autoriteitpersoonsgegevens.nl
Confidential/Registered
Netflix International B.V.
Attn: Management
Karperstraat 10
1075 KZ AMSTERDAM

Date

November 26, 2024

Our reference

[CONFIDENTIAL]

Contact person

[CONFIDENTIAL]

Subject

Decision to impose an administrative fine for violating the GDPR

Dear members of the management,

The Authority for Personal Data (hereinafter: the AP) has decided to impose an administrative fine of € 4,750,000 (say: four million seven hundred fifty thousand euros) on Netflix International B.V.

(hereinafter: Netflix) because Netflix has insufficiently informed its customers; firstly in its privacy statement and secondly in response to access requests regarding 1) purposes and legal bases for the processing of personal data 2) recipients of personal data; 3) retention periods; and 4) international transfers. This constitutes a violation of Article 5, first paragraph, under a, of the General Data Protection Regulation (hereinafter: the GDPR) in conjunction with Article 12, first paragraph, Article 13, first paragraph, under c, e, and f, and second paragraph, under a, and Article 15, introductory part and first paragraph, under a, c and d, and second paragraph, GDPR.

This decision explains the administrative fine. To this end, it successively addresses the background, the established facts and the process, the violation, and the amount of the fine. Finally, the dictum follows.

Date

November 26, 2024

Our reference

[CONFIDENTIAL]

2/23

1. Background of the investigation

1. Netflix is a streaming service that provides digital entertainment such as series, movies, and games. Netflix customers can watch movies and series from Netflix via their TV, tablet, smartphone, and on their computer (via an internet browser). To use these services, Netflix customers must register and create an account for a fee. For this registration, they provide personal data to Netflix, such as their first name, last name, date of birth, email address, phone number, and bank account number. After registration, the customer can watch movies and series from Netflix. This viewing behavior is relevant for Netflix, as it enables Netflix to serve its customers with movies and series that they find interesting. Therefore, Netflix also processes data about its customers' viewing behavior.

2. Netflix has established a privacy statement that provides insight to customers about how personal data is processed. Netflix has also set up a "help center" where customers can ask questions and make requests, for example, to gain access to their personal data.

3. Such an access request was made by None Of Your Business (hereinafter: NOYB) on behalf of two

individuals. Netflix's response to this was the reason for NOYB to file complaints on behalf of the two individuals against Netflix with the Austrian privacy authority (the Datenschutzbehörde). NOYB complains that Netflix insufficiently informs its customers who have made an access request about the processing of their personal data. The Datenschutzbehörde forwarded the complaints to the AP, after which the International Research Department of the AP initiated an investigation and prepared a report. The AP regrets that this investigation took a long time and apologizes for this to both the complainants and Netflix.

2. Findings of the investigation report and process

4. It is established that conclusions in the investigation report that do not form part of the assessment framework of this decision (naturally) fall outside the scope of this decision. This means that no judgment will be made in this decision regarding the accuracy of those conclusions.

5. Regarding the privacy statement, the investigation report indicates that Netflix has not fulfilled its information obligation because Netflix provides insufficient information about:

- a. the purposes and legal basis for the processing of personal data;
- b. parties that receive personal data from data subjects;
- c. the retention period of personal data; and
- d. safeguards for the transfer of personal data to third countries.

1 NOYB is an organization that advocates for the privacy of citizens.

2 File documents 2.1 and 2.5, attached to the investigation report.

3 File document 1, attached to the investigation report.

Date

November 26, 2024

Our reference

[CONFIDENTIAL]

3/23

6. Regarding the access requests, the investigation report indicates that Netflix has not fulfilled its information obligations, as Netflix:

- a. does not provide sufficiently specific information per purpose regarding the basis for processing, the purposes, and processing of personal data;
- b. does not specify which personal data of data subjects has been provided for which purposes and to which recipients;
- c. provides insufficient information about the retention period of personal data; and
- d. provides insufficient information about safeguards when transferring personal data to third countries.

7. The International Research Department concluded in the investigation report that Netflix has provided insufficient information in its privacy statement and thereby violated Article 12, paragraph 1, in conjunction with Article 13, paragraphs 1 and 2, of the GDPR during the period from May 25, 2018, to July 30, 2020. The International Research Department also concluded in the investigation report that Netflix has responded insufficiently specifically to access requests and thereby violated Article 12, paragraph 1, of the GDPR in conjunction with Article 15, paragraphs 1 and 2, of the GDPR during the period from October 25, 2018, to November 19, 2019.

8. The investigation report was sent to Netflix by letter dated March 24, 2022. Netflix provided its comments on the investigation report by letter dated May 17, 2022. On July 7, 2022, Netflix elaborated on its comments orally. A report was made of this.

3. Legal Framework

9. The AP refers to the annex to this decision, which contains the legal framework.

4. Comments from Netflix

10. Netflix has provided the following comments on the report.

11. Netflix asserts that the transparency obligations arising from the GDPR contain open norms.

According to Netflix, however, the AP seems to adopt a stricter interpretation of those obligations. Although these obligations are further elaborated in the Guidelines of the European Data Protection Board⁴ (hereinafter: EDPB Guidelines), a data controller, according to Netflix, has a certain degree of freedom to convey the processing of personal data and the information to be provided in a manner that achieves an appropriate level of transparency.

4 EDPB Guidelines on Transparency under Regulation 2016/679 (wp260rev.01).

Date

November 26, 2024

Our reference

[CONFIDENTIAL]

4/23

12. Netflix believes that it has aligned its operations with these obligations and therefore complies with the four information obligations mentioned above. The (stringent) approach of the AP leads to legal uncertainty for Netflix, as it remains uncertain about how it should act.

13. To support its position that Netflix complies with the information obligations, Netflix states the following.

14. Netflix disagrees with the AP that the offering of its subscription service involves "complex, technical, or unexpected data processing" as described in the EDPB guidelines. Netflix has a straightforward business model; it concerns a subscription service that provides personalized access to, among other things, series. According to Netflix, there is therefore no obligation to describe the main consequences of the processing of personal data. Moreover, the personalized nature of the Netflix services is already emphasized during the registration process. This process consists of signing up for the services that Netflix offers. The customer must provide personal and payment information and agree to the terms that Netflix applies to its services.

15. Netflix also argues that since May 2018, it has provided extensive and understandable explanations through its "help center" regarding, for example, how the so-called recommendation system of Netflix works. According to Netflix, the use of personal data in connection with recommendations is uncomplicated and consistent. From this, Netflix concludes that it complies with the information obligations.

16. Regarding its privacy statement, Netflix states that it has tailored that statement to the TV User Interface (hereinafter: TV UI) because most customers use the television as a platform for watching movies and series. From the perspective of uniformity and transparency of information, Netflix uses the same information on the TV UI as on other platforms (mobile, tablet, internet browser). While the TV UI has a more limited functionality than an internet browser in that regard, this does not affect its privacy statement. Netflix believes that its privacy statement is drafted in a detailed manner without being too long or complicated. Furthermore, Netflix points out that it makes references in the text of the privacy statement to paragraphs with more specific information on a particular subject. With this approach, Netflix has provided sufficient information in its privacy statement in a layered manner (as prescribed by the EDPB guidelines) and has thus complied with the information obligations.

17. Netflix further argues that it does not need to include an exhaustive list of processing activities in its privacy statement. Article 23, paragraph 1, GDPR in conjunction with Article 41 of the Implementation Act GDPR (hereinafter: UAVG) provides that leeway if including that information could lead to circumventing security or anti-fraud measures.

18. Netflix also believes that an obligation to name recipients of personal data in the privacy statement does not follow from Article 13, paragraph 1, GDPR. Therefore, it believes it can suffice with naming only categories of recipients.

Date

November 26, 2024

Our reference

[CONFIDENTIAL]

5/23

19. Finally, Netflix refers to its privacy statement, which informs customers to contact the Netflix Privacy Team with any questions regarding the use of personal data, cookies, or similar technologies. According to Netflix, there is limited use of obtaining information about international transfers, but in cases where this information has been requested, Netflix has fulfilled its transparency obligation.

5. Assessment

5.1. Data Controller and Competence of the AP

20. Netflix is the data controller (Article 4, introductory part and under 7, GDPR). Netflix has its main establishment in Amsterdam, while its privacy statement indicates that it is the data controller for all companies within the Netflix corporate group for the processing of personal data in the European Union (hereinafter: EU). Netflix offers its services in multiple EU member states and for these services, Netflix processes personal data of data subjects. This means that data subjects in more than one member state experience significant consequences from the processing of personal data by Netflix. This constitutes cross-border processing (Article 4, introductory part and under 23, sub b, GDPR).

21. Given the location of Netflix and its role as data controller, the AP is competent to act as the lead supervisory authority (Article 56, paragraph 1, GDPR).

5.2. Information Obligation and Right of Access

22. In this case, the topics of 'information obligation' and 'the right of access' relate to the following four subcomponents, namely: 1) grounds and purposes of processing personal data, 2) recipients of personal data, 3) retention periods, and 4) international transfers. The remaining eight subcomponents, as contained in Articles 13 and 15 GDPR, are outside the scope of this case. This case is limited to the four subcomponents mentioned above. Below, the privacy statement of Netflix is summarized in generic terms, followed by an assessment per subcomponent for both the right of data subjects to receive information when personal data is collected from them (Article 13 GDPR) and the right of access (Article 15 GDPR).

5.2.1. Assessment of Grounds and Purposes of Processing Personal Data

23. The AP has established that the privacy statement of Netflix provides a list of personal data and the manner in which Netflix collects this personal data. This includes: data provided by data subjects themselves, data automatically collected by Netflix, data from other

5 Document 14, attached to the investigation report.

6 Investigation report, par. 3.1.

Date

November 26, 2024

Our reference

[CONFIDENTIAL]

6/23

companies with which the data subjects have a relationship and data from other sources. Subsequently, Netflix provides a list of the purposes for which it uses the collected data. In doing so, Netflix uses several examples to clarify these purposes. One of these is communicating about Netflix's services, including special offers, promotional announcements, and new content. Netflix concludes this with a list of the legal bases for collecting personal data and some references to specifically named purposes. It is established that Netflix identifies four legal bases under Article 6, paragraph 1, GDPR for the processing of personal data, namely: "consent," "contract," "legal obligation," and "legitimate interest."

24. Netflix has submitted documents indicating that it has categorized eight purposes, which further consist of multiple subcomponents. These purposes are more extensive than the purposes included in

Netflix's privacy statement. Upon request, Netflix has clarified which personal data is processed for which purposes and with which legal basis(es). In this context, data subjects must be informed of both the fact that processing takes place and the purposes thereof. This means that Netflix must make the connection between the processing of personal data and the purposes for which the personal data is processed transparent and understandable in its privacy statement. The AP acknowledges that providing information based on a TV UI entails limitations. The information to be provided will generally be visualized in plain text, and the ability to use links to subpages was, at the time of relevance, limited. Furthermore, operating the TV UI with a remote control has limitations compared to other devices such as a computer, tablet, or smartphone. Although the AP takes these circumstances into account, it finds that Netflix has not fully or clearly provided certain information. In this case, Netflix has notably failed to clarify which data it uses for recommending its offerings, analyzing target groups, and preventing fraud. Furthermore, Netflix has not clarified which personal data it receives from third parties (referred to as 'partners' in the privacy statement) to determine the geographical locations of data subjects. Although Netflix has made use of the discretion available to a data controller by narratively including the relevant information in the privacy statement, it should have recognized that decoupling personal data from the purposes for which this personal data is processed results in the provided information not aligning with the requirement to provide information in a concise, transparent, understandable, and easily accessible form and in clear and plain language (Article 12, paragraph 1, GDPR). Given the privacy statement and the manner in which information about the required information has been provided, Netflix has violated Article 13, paragraph 1, sub c, and Article 15, paragraph 1, sub a, GDPR. This means that the complaint from NOYB on this point is well-founded.

7 Document 6.1, pp. 2-3, attached to the investigation report.

8 Document 8.1, pp. 1-13, attached to the investigation report.

9 Recital 60 of the GDPR.

Date

November 26, 2024

Our reference

[CONFIDENTIAL]

7/23

5.2.2. Assessment of recipients of personal data

25. The AP establishes that from Netflix's privacy statement it follows that they use service providers (who are active in the advertising market, among others) and that these service providers may process and disclose personal data of Netflix customers.

26. The privacy statement of Netflix does not provide the names of these recipients, while data provided by Netflix to the AP shows that they do have this information regarding online advertising services.¹⁰

27. Article 13 introductory phrase and first paragraph, under e, of the GDPR indicates that in relevant cases the data controller provides information to data subjects about who the recipients or categories of personal data are. The GDPR (recital 58) states that it is difficult for a data subject to understand by whom and for what purpose their personal data is collected when it comes to information such as that from online advertising services. In accordance with the principle of fairness, Netflix must provide information about the recipients that is most meaningful to the data subjects. In this regard, the AP cannot see why Netflix has not included the names of recipients, which are limited in number, in its privacy statement. The AP is of the opinion that Netflix should have done so and should have provided this information in the event of a request for access. Netflix has wrongfully failed to do this, thereby violating the GDPR (Article 13, first paragraph, under e, and Article 15, first paragraph, under c). The complaint from NOYB on this point is therefore well-founded.

28. The AP establishes that Netflix, with the amendment of its privacy statement on July 7, 2022, added a link to a "help article" containing a list of recipients of personal data. With this, Netflix has ended the violation of the GDPR regarding the "recipients of personal data."

5.2.3. Assessment of retention periods

29. The privacy statement of Netflix indicates that the personal data of data subjects are retained as required or permitted by law and regulations. In this context, Netflix mentions several examples such as retaining personal data to comply with the choices of data subjects and for billing and administrative purposes. No specific retention periods are mentioned in the privacy statement.

30. Upon request, Netflix submitted a table to the AP detailing the personal data that are retained and the specific retention periods applicable to them.¹¹ The AP establishes that Netflix has failed to include these periods in its privacy statement. The AP has not found that Netflix would have had to take disproportionately many measures for this.

10 File document 8.4, p. 4, attached to the investigation report.

11 File document 6.1, p. 11-13, attached to the investigation report.

****Date****

November 26, 2024

****Our reference****

[CONFIDENTIAL]

8/23

31. The AP is of the opinion that Netflix has not provided the periods during which personal data is retained – in its privacy statement and in response to access requests – in a proper and transparent manner to the data subjects. Thus, Netflix has acted in violation of the GDPR (Article 13, paragraph 2, under a, and Article 15, paragraph 1, under d). The complaint from NOYB is therefore well-founded on this point.

32. Netflix's argument that the AP's privacy statement also only mentions the retention of personal data in accordance with applicable laws and regulations does not change this. The processing register of the AP can be consulted on the AP's website, and the retention periods are specified therein. Furthermore, the AP's privacy statement has been brought into compliance with the GDPR.

****5.2.4. Assessment of international transfer of personal data****

33. The AP notes that from Netflix's privacy statement, it follows that when transferring personal data to countries outside the European Economic Area (EEA), it acts in accordance with the applicable privacy legislation of those countries. The AP further notes that information provided by Netflix upon request indicates that Netflix can process personal data in twelve countries outside the EU for the purpose of executing payments, customer service, and scaling and improving the availability of its services.

34. In the opinion of the AP, Netflix has failed to include in its privacy statement what rights data subjects have when their personal data is processed outside the EEA. Netflix has also not specified in its privacy statement to which countries outside the EEA personal data of data subjects are transferred. Additionally, Netflix has failed to make a reference to any adequacy decisions and has not indicated whether (in the relevant case) there are suitable or appropriate safeguards and how data subjects can consult those safeguards.

35. The AP concludes that the information that Netflix included in its privacy statement at least until July 31, 2020, does not meet the requirements of the GDPR (Article 13, paragraph 1, under f). The AP adds that Netflix, in response to access requests during the period from October 25, 2018, to November 19, 2019, failed to provide sufficient information regarding safeguards for transfers of personal data to third countries. Thus, Netflix has also acted in violation of the GDPR (Article 15, paragraph 2), making the complaint from NOYB well-founded in this respect.

36. The AP notes that Netflix has amended its privacy statement on this point as of July 7, 2022, by including a link to the European Commission's webpage. Visitors to that website are redirected to a question-and-answer document that includes the rights of data subjects when there is an international transfer of personal data. Additionally, as of July 7, 2022, Netflix has included a link to a 'help article' in

its privacy statement that contains a list of the countries to which personal data is transferred. Although Netflix has included a list of countries to which personal data may be sent, this does not satisfy Article 13,

Date

November 26, 2024

Our reference

[CONFIDENTIAL]

9/23

first paragraph, under f, GDPR and Article 15, second paragraph, GDPR fulfilled, as it is not evident what appropriate or suitable safeguards have been implemented for the intended transfers.

5.3. Principle of Care

37. Netflix argues that the AP acted contrary to the principle of care by not providing Netflix the opportunity to respond to the draft investigation report.

38. The AP states that the investigation report was sent to Netflix on March 24, 2022. Netflix was then given the opportunity to provide its views on that report. Netflix made use of this opportunity by submitting a written opinion and also elaborating on that opinion orally to the AP. According to the AP, there is therefore no violation of the principle of care.

5.4. Conclusion

39. The AP concludes that Netflix has insufficiently informed its customers; firstly in its privacy statement and secondly in response to access requests regarding 1) the grounds and purposes of processing personal data; 2) recipients of personal data; 3) retention periods; and 4) international transfers. In doing so, Netflix has acted in violation of Article 5, first paragraph, under a, in conjunction with Article 12, first paragraph, GDPR and Article 13, first paragraph, introductory part and under c, e, and f, and second paragraph, introductory part and under a, GDPR during the period from May 25, 2018, to July 30, 2020. Netflix has also violated Article 5, first paragraph, under a, in conjunction with Article 12, first paragraph, GDPR and Article 15, first paragraph, introductory part and under a, c, and d, and second paragraph, GDPR during the period from October 25, 2018, to November 19, 2019. For these violations, the AP will impose a fine on Netflix. The amount of the fine will be determined subsequently.

6. Administrative Fine

6.1. Authority to Impose Fines

40. The AP is authorized to impose an administrative fine based on Article 58, second paragraph, introductory part and under i, in conjunction with Article 83 GDPR and read in conjunction with Article 14, third paragraph, UAVG. Jurisprudence from the Court of Justice of the European Union (hereinafter: CJEU) indicates that the wording of Article 83, second paragraph, GDPR implies that breaches of the provisions of the GDPR committed by the data controller in a culpable manner – that is, intentional or negligent breaches – may lead to an administrative fine being imposed on the data controller under that article.¹²

¹² CJEU December 5, 2023, C-683/21, ECLI:EU:C:2023:949 (NVSC) paragraphs 73 and 83; CJEU December 5, 2023, C-807/21, ECLI:EU:C:2023:950 (Deutsche Wohnen) paragraphs 68 and 76.

Date

November 26, 2024

Our reference

[CONFIDENTIAL]

10/23

6.2. Methodology for Determining the Amount of the Fine

41. The EDPB approved the final text of the Guidelines 04/2022 for calculating administrative fines

under the GDPR (hereinafter: the Guidelines) in its plenary meeting on May 24, 2023.¹³ The AP will apply these Guidelines to this case.¹⁴

42. The Guidelines describe the following method for calculating administrative fines for breaches of the GDPR:

1. identify which and how many actions and breaches are under assessment;
2. determine the starting amount for the further calculation of the fine;
3. assess whether there are mitigating or aggravating circumstances that necessitate an increase or decrease of the fine;
4. check what maximum amounts apply for the violations and whether those maximum amounts are not exceeded as a result of increases applied in previous or subsequent steps;
5. verify whether the calculated final amount of the fine meets the requirements of effectiveness, deterrence, and proportionality, and adjust the fine accordingly if necessary.

43. These steps will be followed in succession.

6.3. Calculation of the Fine Amount

6.3.1. Step 1: Establishing Actions and Breaches

44. First, it must be established whether there is one or more behaviors that need to be sanctioned. In section 5.4, it was determined that Netflix has insufficiently informed its customers in its privacy statement and in response to access requests regarding 1) the grounds and purposes of processing personal data; 2) recipients of personal data; 3) retention periods; and 4) international transfers. In light of this, Netflix has committed two distinct sanctionable behaviors. These behaviors consist of insufficiently informing customers; firstly in the privacy statement and secondly in response to access requests. This means that in this case, there are two culpable behaviors for which the AP can impose fines.

6.3.2. Step 2: Determining the Starting Amount

45. Next, the starting amount of the fine must be determined. This amount serves as the basis for further calculations in later steps, taking into account all relevant facts and circumstances. The starting amount is determined based on three elements:

¹³ See also Guidelines 04/2022 for calculating administrative fines under the GDPR.

¹⁴ See also

<https://www.autoriteitpersoonsgegevens.nl/actueel/nieuw-boetebeleid-voor-overtredingen-avg>
Date

November 26, 2024

Our reference

[CONFIDENTIAL]

11/23

i)

the categorization of the violations according to Article 83, paragraphs 4 to 6 GDPR;

ii)

the severity of the violation; and

iii)

the turnover of the company.

Ad i) Categorization of the violations according to Article 83, paragraphs 4 to 6 GDPR

46. As stated in the Guidelines on the calculation of administrative fines, almost all obligations of the data controller are categorized under the provisions of Article 83, paragraphs 4 to 6 GDPR. The GDPR distinguishes between two types of violations. On the one hand, violations that are sanctionable under Article 83, paragraph 4, GDPR, for which a maximum fine of €10 million applies (or in the case of a company, 2% of the annual turnover, if that is higher); on the other hand, violations that are sanctionable under Article 83, paragraphs 5 and 6 GDPR, for which a maximum fine of €20 million

applies (or in the case of a company, 4% of the annual turnover, if that is higher). With this distinction, the legislator has provided an initial indication in abstracto of the seriousness of the violation: the more serious the violation, the higher the fine.

47. In this case, for the violation of Article 5, paragraph 1, sub a, in conjunction with Article 12, paragraph 1, GDPR and Article 13, paragraph 1, introductory phrase and sub e and f, and paragraph 2, introductory phrase and sub a, GDPR, and the violation of Article 5, paragraph 1, sub a, in conjunction with Article 12, paragraph 1, GDPR and Article 15, paragraph 1, introductory phrase and sub c and d, and paragraph 2, GDPR, an administrative fine of up to €20 million (or in the case of a company, 4% of the global annual turnover, if that is higher) can be imposed. From this categorization, it follows that the violations of these provisions are considered serious by the legislator.

Ad ii) Severity of the violation

48. In determining the severity of the violation, account must be taken of the nature, seriousness, and duration of the infringement, as well as the intentional or negligent nature of the violation and the categories of personal data involved.

49. The nature of the first violation in this case is the obligation of the data controller to provide the data subject with the information necessary to ensure fair and transparent processing towards data subjects, taking into account the specific circumstances and the context in which the personal data are processed. For the second violation, namely the restriction of the right of access, it is also necessary, as is the right to receive understandable and easily accessible information about the processing of personal data, to enable data subjects to exercise their other rights under the GDPR. Providing transparent information in the sense of Article 12, paragraph 1, GDPR is therefore of great importance. When the rights of data subjects are not respected, this affects the right that data subjects have to respect for their private life and the protection of their personal data.

15 Recital 60 of the GDPR.

****Date****

November 26, 2024

****Our reference****

[CONFIDENTIAL]

12/23

50. In assessing the severity of the violations, the number of Netflix customers who may be affected by these violations is also taken into account. At the end of 2022, Netflix had approximately 231 million paying customers worldwide, a substantial portion of whom are in the European Union. This means that the processing of personal data has a broad scope and potentially affects a large number of data subjects. Although Netflix provides relevant information in its privacy statement regarding the collection of personal data from data subjects, the purposes of this processing, and the legal bases on which Netflix relies, as well as information about 'recipients of personal data', 'retention periods', and 'international transfers', the AP believes that the information provided is not specific enough. As a result, data subjects were hindered in exercising control over their personal data. Netflix has indicated, upon request, that it receives approximately one million inquiries annually through its 'help center' worldwide, the vast majority of which are technical questions, and that only a very small portion pertains to questions about (access to) personal data. The fact that not all customers, but only a relatively limited number of customers, had questions or complaints regarding the right to access somewhat mitigates the severity of the infringement, in the opinion of the AP.

51. Regarding the duration of the violations, it has been established that they lasted from May 25, 2018, to November 19, 2019, and respectively until July 30, 2020. Although this is a significant period, the AP also takes into account the fact that the investigation took a long time. During this period, Netflix repeatedly expressed its willingness to adjust its privacy statement based on recommendations from the AP. After the investigation report was sent to Netflix, Netflix voluntarily adjusted its privacy statement at multiple points in time with the aim of specifying the information and thus addressing the

shortcomings identified by the AP. The fact that the handling of this case by the AP took a long time (investigation and enforcement phase) and that the AP did not respond to Netflix's willingness to amend its privacy statement will be taken into account by the AP in determining the amount of the fine.

52. Furthermore, in determining the severity of the infringement, it must be assessed whether the infringement was intentional or negligent. The severity of the infringement carries more weight when the data controller has knowingly committed a violation. When the infringement is the result of careless behavior, the severity of the infringement carries less weight. The AP takes into account the fact that Netflix modeled its privacy statement on a TV UI that undoubtedly has limited functionalities. The information to be provided was visualized in plain text, and the ability to use links or 'sidebars' to subpages was, at the time, limited. Additionally, operating the TV UI with a remote control has limitations compared to other devices such as a computer, tablet, or smartphone. The AP also considers that Netflix wanted to maintain the uniformity of its Privacy Statement by not making the content of its privacy statement dependent on the device used to access Netflix's services. Taking these circumstances into account, the AP concludes that Netflix did not provide certain information completely or clearly. In this case, Netflix should have reviewed its privacy statement more frequently and critically against...

Date

November 26, 2024

Our reference

[CONFIDENTIAL]

13/23

the light should have been maintained, which should have led to an adjustment of that statement. By failing to do so, Netflix has provided insufficiently clear information in its privacy statement regarding 1) the legal bases and purposes of processing personal data; 2) recipients of personal data; 3) retention periods; and 4) international transfers. In doing so, Netflix has been negligent in its actions to comply with the GDPR.

53. Furthermore, the categories of personal data to which the breach relates are the final piece for assessing the severity of the breach. In this case, there is no processing of special categories of personal data within the meaning of Articles 9 and 10 of the GDPR.

54. The AP is of the opinion that, taking the preceding circumstances into account, in this case, the severity of the breach should be classified as low, as it cannot be said that Netflix has been entirely non-compliant regarding the transparency obligations referred to here.

Ad iii) Revenue of the company

55. A fair starting amount for the fine must be related to the size of the company. The size of the company is determined based on revenue. The starting amount for a small company is lower, and the starting amount increases as the revenue of the company is higher. If a company has revenue of more than €500 million, the amount of the fine is determined as a percentage of the company's annual revenue.¹⁶ This means that the size and revenue of the company have already been factored into the amount of the fine, so the starting amount does not need to be adjusted on that basis.

56. For determining Netflix's revenue, it must be viewed in that context as a company in accordance with Articles 101 and 102 of the Treaty on the Functioning of the European Union (TFEU). Netflix is a wholly-owned subsidiary of Netflix Inc., based in Los Gatos, California (United States). According to the case law¹⁷ of the Court of Justice of the European Union, the revenue of the entire group must be used to establish the upper limit of the fine.

57. For determining the revenue, data from the financial year preceding the imposition of a fine is used. In this case, that is the data for the financial year 2023.

58. From the consolidated annual report¹⁸ of Netflix Inc. for 2023, it follows that the group had revenue of €30.733 billion (\$33.723 billion) that year.¹⁹ According to Article 83, paragraph 5, of the GDPR, for

violations of Articles 12 to 22 of the GDPR, an administrative fine of up to €20 million or

16 From an annual revenue of €500 million, it is the case that 4% of the annual revenue exceeds €20 million, so this percentage must be considered as the maximum fine (Article 83, paragraph 5, introductory sentence of the GDPR).

17 Groupe Gascogne SA/European Commission (Case C-58/12P, judgment of November 26, 2013), ECLI:EU:C:2013:770, § 52-57.

18 Consolidated annual report of Netflix Inc. 2023, p. 39.

19 The exchange rate determined by the ECB on the day of this decision is €0.9104 per US dollar (see).

Date

November 26, 2024

Our reference

[CONFIDENTIAL]

14/23

in the case of a company, 4% of the global annual turnover, if that is higher. This means that the maximum fine to be imposed is €1.229 billion.

6.3.3. Step 3: Assessing other relevant circumstances

59. According to the Guidelines for calculating administrative fines, it must then be examined whether the circumstances of the case provide grounds for setting the fine higher or lower than the aforementioned starting amount. The circumstances to be considered are listed in Article 83, second paragraph, introductory phrase and under a to k, GDPR. The circumstances mentioned in that provision must each be considered only once. In the previous step – to the extent applicable – account has already been taken of the nature, severity, and duration of the violation (part a), the intentional or negligent nature of the infringement (part b), and the categories of personal data (part g). Therefore, only parts c to f and h to k remain.

60. In this case, the AP takes into account that Netflix responded in a timely manner to the access requests by providing collected personal data as well as data regarding, among other things, viewing behavior, search history, IP addresses, payments, devices, and interaction with Netflix. Furthermore, Netflix also provided a copy of its privacy statement along with the aforementioned data. After receiving this data, NOYB filed complaints with the Datenschutzbehörde on behalf of the affected parties, while Netflix believed that it had satisfactorily handled the requests from the affected parties. Netflix also terminated the violation regarding the 'recipients of personal data' shortly after receiving the investigation report. Thus, Netflix did not await the decision-making of the AP but promptly supplemented the available information and made it available in multiple languages to the users of its service. The aforementioned circumstances, including the long duration of the handling of this case by the AP and the lack of response from the AP to Netflix's willingness to amend its privacy statement, are reasons for the AP to reduce the amount of the fine to be determined below from the perspective of proportionality (par. 97 Guidelines for calculating administrative fines).

6.3.4. Step 4: Relevant maximum amounts

61. Given Netflix's turnover, a maximum fine amount of €1.229 billion or 4% of the annual turnover will apply for the identified violations. It has been considered that in this case, the severity of the infringement should be classified at a low level. According to the Guidelines, for infringements with a low level of seriousness, the starting amount should be determined at a point between 0 and 10% of the maximum fine. This means that the range of the fine to be imposed is between 0% and 10% of €1.229 billion. This corresponds to an amount between €0 and €122.9 million. Taking into account all the relevant facts and circumstances mentioned above, the AP sets the starting amount at €2.5 million per violation. Since two violations have been identified, the starting amount will be €5 million. This amount is well below the maximum fine of 4% of Netflix's global annual turnover.

Date

November 26, 2024

Our reference

[CONFIDENTIAL]

15/23

6.3.5. Step 5: Assessment of the requirements of effectiveness, proportionality, and deterrence

62. Finally, it must be assessed whether the fine is effective, proportional, and deterrent. Article 49, third paragraph, of the Charter of Fundamental Rights of the EU and Articles 3:4 and 5:46, second paragraph, General Administrative Law Act (Awb) indicate that the administrative fine, given the circumstances of the case, does not lead to an disproportionate outcome.

63. As described in the Guidelines, the imposition of a fine can be considered effective if it achieves the purpose for which it was imposed. That purpose may lie in, on the one hand, punishing unlawful behavior and, on the other hand, promoting compliance with applicable regulations. Considering the nature, seriousness, and duration of the infringement, as well as the other factors from Article 83, second paragraph, GDPR as assessed above and taking into account the mitigating circumstance mentioned in paragraph 6.3.3, the AP is of the opinion that the imposition of an administrative fine under these circumstances achieves both goals and is therefore effective and deterrent. The amount of the administrative fine, which is also determined based on Netflix's turnover, is also considered effective and deterrent by the AP.

64. The AP considers a fine of €4,750,000, given the seriousness of the violations and the size of the company, to be proportional. In the opinion of the AP, there is no evidence of special circumstances that would make the fine disproportionate.

7. Disposition

65. The AP imposes on Netflix an administrative fine of €4,750,000 (say: four million seven hundred fifty thousand euros) for violating Article 5, first paragraph, under a, in conjunction with Article 12, first paragraph, GDPR, and Article 13, first paragraph under c, e, and f, and second paragraph, under a, GDPR respectively Article 5, first paragraph, under a, in conjunction with Article 12, first paragraph, GDPR, and Article 15, first paragraph, under a, c, and d, and second paragraph, GDPR.

Yours sincerely,

Data Protection Authority,

mr. A. Wolfsen

Chairman

Date

November 26, 2024

Our reference

[CONFIDENTIAL]

16/23

Remedies Clause

If you disagree with this decision, you may submit a notice of objection to the Authority for Personal Data within six weeks of the date of dispatch of the decision, either digitally or on paper. Pursuant to Article 38 of the GDPR, the submission of a notice of objection suspends the effect of the order imposing the administrative fine. The AP will only proceed to collection after the decision has become irrevocable.

For submitting a digital objection, see www.autoriteitpersoonsgegevens.nl, under the heading "Making an objection against a decision," at the bottom of the page under the heading "Contact with the Authority for Personal Data."

The address for submitting on paper is:

Autoriteit Persoonsgegevens, P.O. Box 93374, 2509 AJ The Hague.

Please indicate on the envelope 'Awb-objection' and include 'notice of objection' in the title of your

letter.

Your notice of objection must include at least:

- your name and address;
- the date of your notice of objection;
- the reference mentioned in this letter (case number); or attach a copy of this decision;
- the reason(s) why you disagree with this decision;
- your signature.

Date

November 26, 2024

Our reference

[CONFIDENTIAL]

17/23

Annex: Legal Framework

General Administrative Law Act

Article 4:7

1.

Before an administrative body wholly or partially rejects an application for a decision, it shall give the applicant the opportunity to present their views if:

- a) the rejection would be based on data concerning facts and interests that affect the applicant, and
- b) that data differs from data that the applicant has provided in this regard.

[...]

Article 5:50

1.

If the offender is given the opportunity to present their views regarding the intention to impose an administrative fine,

- a) the report shall already be sent or handed over to the offender with the invitation;
- b) the administrative body shall provide assistance by an interpreter if it appears that the defense of the offender reasonably requires this.

2.

If the administrative body decides after the offender has presented their views that:

- a) no administrative fine will be imposed for the violation, or
 - b) the violation will still be submitted to the public prosecutor,
- this will be communicated to the offender in writing.

General Data Protection Regulation

Article 4

Definitions

For the purposes of this regulation, the following definitions apply:

1) "personal data": any information relating to an identified or identifiable natural person ("the data subject"); an identifiable natural person is one who can be identified, directly or indirectly, particularly by reference to an identifier such as a name, an identification number, location data, an online identifier, or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that natural person;

[...]

7) "data controller": a natural or legal person, a public authority, an agency, or any other body that, alone or jointly with others, determines the purposes and means of the processing of personal data; when the purposes and means of such processing are determined by Union law or the law of a Member State, it may be provided who the data controller is or the criteria for its designation;

[...]

23) "cross-border processing":

- a) processing of personal data in the context of the activities of establishments in more than one Member State of a data controller or a processor in the Union that is established in more than one

Member State; or

b) processing of personal data in the context of the activities of a single establishment of a data controller or of a processor in the Union, which affects or is likely to affect data subjects in more than one Member State;

[...]

Article 5

1. Personal data must:

a) be processed in a manner that is lawful, fair, and transparent with respect to the data subject ("lawfulness, fairness, and transparency");

[...]

Article 12

Transparent information, communication, and additional rules for the exercise of the rights of the data subject

1. The data controller shall take appropriate measures to ensure that the data subject receives the information referred to in Articles 13 and 14 and the communication referred to in Articles 15 to 22 and Article 34 regarding the processing in a concise, transparent, intelligible, and easily accessible form, using clear and plain language, particularly when the information is addressed specifically to a child. The information shall be provided in writing or by other means, including, where appropriate, by electronic means. If the data subject requests it, the information may be provided orally, provided that the identity of the data subject is proven by other means.

Date

November 26, 2024

Our reference

[CONFIDENTIAL]

19/23

[...]

Article 13

Information and Access to Personal Data

1. When personal data concerning a data subject is collected from that person, the data controller shall provide the data subject with the following information at the time of obtaining the personal data:

a) the identity and contact details of the data controller and, where applicable, of the data controller's representative;

b) where applicable, the contact details of the data protection officer;

c) the purposes of the processing for which the personal data are intended, as well as the legal basis for the processing;

d) the legitimate interests of the data controller or a third party, if the processing is based on Article 6(1)(f);

e) where applicable, the recipients or categories of recipients of the personal data;

f) where applicable, that the data controller intends to transfer the personal data to a third country or an international organization; whether or not there is an adequacy decision by the Commission; or, in the case of transfers referred to in Article 46, Article 47, or Article 49(1), second paragraph, what the appropriate or suitable safeguards are, how a copy can be obtained, or where they can be consulted.

2. In addition to the information referred to in paragraph 1, the data controller shall provide the data subject with the following additional information at the time of obtaining the personal data to ensure fair and transparent processing:

a) the period for which the personal data will be stored, or if that is not possible, the criteria used to determine that period;

[...]

Article 15

Right of Access of the Data Subject

1. The data subject has the right to obtain from the data controller confirmation as to whether or not personal data concerning him or her is being processed and, where that is the case, to access that

personal data and the following information:

- a) the purposes of the processing;
- b) the categories of personal data concerned;

Date

November 26, 2024

Our reference

[CONFIDENTIAL]

20/23

- c) the recipients or categories of recipients to whom the personal data have been or will be disclosed, in particular recipients in third countries or international organizations;
- d) where possible, the period for which the personal data is expected to be stored, or if that is not possible, the criteria used to determine that period;
- e) that the data subject has the right to request the data controller to rectify or erase personal data concerning him or her, or to restrict the processing of personal data concerning him or her, as well as the right to object to such processing;
- f) that the data subject has the right to lodge a complaint with a supervisory authority;
- g) when the personal data is not collected from the data subject, all available information about the source of that data;
- h) the existence of automated decision-making, including profiling as referred to in Article 22(1) and (4), and at least in those cases, meaningful information about the logic involved, as well as the significance and the expected consequences of that processing for the data subject.

2. When personal data is transferred to a third country or an international organization, the data subject has the right to be informed of the appropriate safeguards in accordance with Article 46 regarding the transfer.

3. The data controller shall provide the data subject with a copy of the personal data undergoing processing. If the data subject requests additional copies, the data controller may charge a reasonable fee based on administrative costs. When the data subject submits his or her request electronically, and unless otherwise requested, the information shall be provided in a commonly used electronic format.

4. The right to obtain a copy referred to in paragraph 3 shall not adversely affect the rights and freedoms of others.

[...]

Article 23

Restrictions

1. The scope of the obligations and rights referred to in Articles 12 to 22 and Article 34, as well as in Article 5, may be restricted by Union or Member State provisions applicable to the data controller or the processor, provided that such restriction does not affect the essence of the fundamental rights and freedoms and is a necessary and proportionate measure in a democratic society to safeguard:

- a) national security;
- b) defense;

Date

November 26, 2024

Our reference

[CONFIDENTIAL]

21/23

- c) public safety;
- d) the prevention, investigation, detection, and prosecution of criminal offenses or the enforcement of penalties, including the protection against and prevention of threats to public safety;
- e) other important objectives of general interest of the Union or of a Member State, in particular a significant economic or financial interest of the Union or of a Member State, including monetary, budgetary, and fiscal matters, public health, and social security;
- f) the protection of the independence of the judiciary and judicial proceedings;

- g) the prevention, investigation, detection, and prosecution of violations of professional codes for regulated professions;
 - h) a task in the field of supervision, inspection, or regulation that is related, even if incidentally, to the exercise of public authority in the cases referred to in points a) to e) and point g);
 - i) the protection of the data subject or the rights and freedoms of others;
 - j) the collection of civil claims.
2. The legal measures referred to in paragraph 1 shall contain, in particular, specific provisions regarding, where applicable, at least:
- a) the purposes of the processing or the categories of processing;
 - b) the categories of personal data;
 - c) the scope of the imposed restrictions;
 - d) the safeguards to prevent abuse or unlawful access or transfer;
 - e) the specification of the data controller or the categories of data controllers;
 - f) the retention periods and the applicable safeguards, taking into account the nature, scope, and purposes of the processing or the categories of processing;
 - g) the risks to the rights and freedoms of the data subjects; and
 - h) the right of data subjects to be informed of the restriction, unless this would undermine the purpose of the restriction.

[...]

Article 56

Date

November 26, 2024

Our reference

[CONFIDENTIAL]

22/23

Competence of the lead supervisory authority

1. Without prejudice to Article 55, the supervisory authority of the main establishment or the sole establishment of the data controller or processor shall be competent to act as the lead supervisory authority for cross-border processing by that data controller or processor in accordance with the procedure laid down in Article 60.

[...]

Article 58

Powers

2. Each supervisory authority has all of the following powers to take corrective measures:

[...]

i) depending on the circumstances of each case, in addition to or instead of the measures referred to in this paragraph, impose an administrative fine under Article 83;

[...]

Article 83

General conditions for imposing administrative fines

[...]

5. Violations of the provisions below are subject to administrative fines of up to 20,000,000 EUR or, for an undertaking, up to 4% of the total worldwide annual turnover in the preceding financial year, whichever is higher:

[...]

b) the rights of data subjects under Articles 12 to 22;

c) the transfers of personal data to a recipient in a third country or an international organization under Articles 44 to 49;

[...]

Implementation Act General Data Protection Regulation

Article 14

Tasks and powers of the Data Protection Authority

[...]

Date

November 26, 2024

Our reference

[CONFIDENTIAL]

23/23

3. The Data Protection Authority may impose an administrative fine of up to the amounts specified in paragraphs four, five, or six of Article 83 of the Regulation in the event of a violation of the provisions therein.